Your role in the incident

SC2632 - From Intent to Enforcement: Agentic Kubernetes Guardrails with Quarantine Mode

The situation: Payment services and automated AI agents share one Kubernetes cluster, network, and API plane. Your case reports suspicious activity while exposure is uncertain.

Two traps to avoid today: (1) **The Green-PR Illusion**—approving a policy agent PR because unit tests pass on Pod CREATE while NetworkPolicy, RBAC, and running pods stay open; (2) **Containment Self-Sabotage**—removing or changing a suspect Pod before evidence capture, and losing volatile process evidence.

The shared platform and its control boundaries

Kubernetes manages containers across machines. **Pods** are running units; **replicas** are copies. **Namespaces** (such as *payments* and *agents*) group resources. **ServiceAccounts** provide bearer tokens for Kubernetes API calls. **Falco & Audit Logs** detect runtime and API activity (they do not auto-trigger quarantine). **Kyverno** checks Pod CREATE/UPDATE at admission (it does not stop running pods or Secret reads). **NetworkPolicy** constrains traffic; **RBAC** constrains API permissions. Humans authorize exceptions, Quarantine Mode (Q0–Q3), and recovery.

Falco rules passed static and synthetic checks; live detection is not part of this session, and incident alerts are supplied exercise facts. The common demo compiles a reference spec and runs policy tests.

Fast start before Round 1 (3 minutes)

1. Take your table's default case (or swap within 30 seconds): Tables 1, 5, 9 → Case A (library update, p. 2) · **Tables 2, 6, 10 → Case B** (support assistant, p. 3) · **Tables 3, 7, 11 → Case C** (ops agent, p. 4) · **Tables 4, 8, 12 → Case D** (Secret reads, p. 5). Read only your selected case.

2. Pick one operating constraint and write a measurable service floor on page 6: Availability (keep 2 Ready replicas & required connections) · **Evidence** (preserve/hash volatile forensics & record approvals) · **Velocity** (keep unaffected releases moving) · **Containment** (stop exposure & justify service impact).

3. Assign 4 roles on page 6: INCIDENT LEAD (calls the vote) · **RECORDER** (writes pages 6–7) · **EVIDENCE ANALYST** (checks supplied facts, then revealed lab evidence) · **INDEPENDENT REVIEWER** (challenges one assumption before locking). Combine roles at smaller tables.

How each round works

Discuss, then **lock your decision in ink on pages 6–7 before each reveal**. Retain your original plan on page 7 and write revisions below it. **Keep pages 8–9 and CONTROL-REVIEW page 2 folded until their round opens.**

No laptop or YAML required. Quarantine Mode (Q0–Q3) is this project's coordinated incident posture; each layer requires explicit verification.

Case A: A library update

Opening alert and environment

09:14. payments-api 2.14.3 shipped three days ago with a metrics-library update. One process in a payments Pod connects to hr-sync and inventory. The service remains operational; the scope of compromise is uncertain. Three payments replicas run behind a Service, with a PodDisruptionBudget requiring two available.

Reference intent for comparison

Deny new east-west communication from payments while preserving known dependencies. Prevent privilege escalation. Restrict the compromised workload's API access. Roll out in stages and time-box exceptions.

Proposal excerpt

Clause/control	Reference proposal
Egress profile	Deny profiles outside the approved list
Privilege escalation	Generate deny-privilege-escalation
Kubernetes API access	NOT IMPLEMENTED. RBAC and ServiceAccount handover.
Registry restriction	Added beyond intent, Audit only

What the evidence says

payments-api passes the privilege and egress checks. backup-job would block under the egress policy. report-runner uses a public registry and is admitted at Audit. With the reference backup-job exception, the egress check skips it.

Round 2 request

backup-job needs temporary storage access. The reference request names platform-ops@trustfall.example and a 24-hour TTL. A separate agent request claims an approval nobody has independently recorded. Decide what proof, scope and shorter expiry you need.

Source: output/frozen-a/PR.md. A/B/C are excerpts, not a claim that your new statement already ran through a model.

Case B: A ticket-reading assistant

Opening alert and environment

09:14. payments-api includes a support-agent sidecar that reads customer tickets and has tools. A process named tool-runner connects to unexpected services. The Pod shares an identity and networking with the payments application. The image came from the approved registry.

Reference intent for comparison

Restrict payments egress to known dependencies. Stop the assistant from using the Pod's Kubernetes identity. Stop unsafe tool behavior. Preserve essential service dependencies.

Proposal excerpt

Clause/control	Reference proposal
Egress profile	Constrain permitted profiles
Assistant identity	Pod-level token control; inspect application impact
Tool behavior	Admission cannot enforce application tool calls
Registry restriction	Added at Audit; does not establish tool safety

What the evidence says

Review the token setting and the egress allow list together. The frozen report simulates admission on Pod fixtures. It does not test whether a support ticket can manipulate an internal database tool. An approved image alone does not establish safe agent behavior.

Round 2 request

The support assistant asks for access to inventory and says the customer ticket author approved it. Is that an accountable owner or untrusted context? Decide whether to refuse, narrow or require independent review.

Source: output/frozen-b/PR.md. A/B/C are excerpts, not a claim that your new statement already ran through a model.

Case C: An ops agent takes chat requests

Opening alert and environment

09:41. system:serviceaccount:agents:ops-agent patches payments-api from 3 to 12 replicas, then hr-sync from 2 to 6. Neither request has a ticket annotation. Its legacy ClusterRole allows patching Deployments across the cluster.

Reference intent for comparison

Keep the ops agent's changes within its own namespace. Require tickets for its changes. Preserve its ability to read what it needs.

Proposal excerpt

Clause/control	Reference proposal
Outside-namespace mutation	Deny changes by the named agent identity
Ticket annotation	Warn initially; tool compatibility needs review
Read access	Outside admission; review RBAC separately
Replica surge	Added at Audit, threshold 8

What the evidence says

The scenario tests requests as the agent and as a human SRE. A policy scoped to the agent identity does not block the human requester. Ask whether a ticket annotation proves approval, and whether the underlying ClusterRole should permit the action.

Round 2 request

The ops team requests four hours of ticket-free payments scaling to maintain service capacity. The agent forwards a command to a human that also widens its RBAC. Decide which request, if any, has verified authority.

Source: output/frozen-c/PR.md. A/B/C are excerpts, not a claim that your new statement already ran through a model.

Case D: A monitoring identity reads Secrets

Opening alert and environment

09:14. The audit log shows system:serviceaccount:payments:monitoring-agent listing Secrets across namespaces in 40 seconds. A past dashboard integration needed one Secret, and its cluster-wide get/list role remains. Metrics still flow. The service remains operational; the scope of compromise is uncertain.

Reference intent for comparison

Stop monitoring-agent reading Secrets outside payments. Preserve metrics and the audit evidence of everything it accessed.

Proposal excerpt

Requirement	Manual review proposal, not generated enforcement
Secret GET/LIST	Admission does not see reads. Hand over to RBAC.
Identity scope	Review bindings and replace excess rights with a scoped Role.
Evidence	Export audit events, identify resources and preserve hashes.
Service continuity	Test monitoring and payment dependencies before rotation.

What the evidence says

Predict the result before the reveal: can a copied token still read Secrets after the Pod is quarantined? Require denied outside-namespace GET/LIST, preserved GET of the exact required in-namespace Secret, and a reachable positive control. A separate real lab recording tests these boundaries with synthetic resources; it does not qualify production metrics delivery or external application-key rotation.

Round 2 request

There is no Kyverno admission exception that fixes this read privilege. A temporary RBAC grant, if needed, requires independently verified approval, precise resource scope, an owner, an expiry and an executed revocation plan.

Source: scenarios/d-secret-enumeration/review/PR.md. RBAC is human-reviewed; generator scenario d is not implemented.. A/B/C are excerpts, not a claim that your new statement already ran through a model.

Your decision record

Table ____ Case ____ Primary constraint _____

Lead _____ Recorder _____ Analyst _____ Reviewer _____

Round 1: intent and PR review

Stop this behavior: _____

Preserve this dependency / minimum service: _____

Requirement and control owner	Required denial and legitimate action to preserve
1. _____	Deny: _____
Owner: _____	Preserve: _____
2. _____	Deny: _____
Owner: _____	Preserve: _____

APPROVE / MODIFY / REJECT / ESCALATE.
What may proceed, and its exact scope: _____

What stays held, and the evidence needed: _____

Round 2: exception and rollout

Grant / narrow / hold / refuse. Exact operation and scope: _____

Owner: _____ Approver: _____

How approval is verified, or why held: _____

Expiry (date, time, timezone): _____ Revocation check: _____

Mode per control: _____ Promotion evidence: _____

Reviewer concern and table response: _____

_____

Continue on page 7. Leave the original containment plan legible after later evidence arrives.

Containment and recovery record

Table ____ Case ____ Continue the same shared record from page 6.

Round 3: original plan before the later finding

Evidence source and preservation step: _____

_____

Order / action	Owner	Test required before claiming success
1. _____	_____	_____
_____		_____
2. _____	_____	_____
_____		_____
3. _____	_____	_____
_____		_____

Level and target: _____ Declaring authority: _____

Minimum service: _____ Escalation trigger: _____

Later finding: revision or defended hold

New fact that matters: _____

Changed action / order, or why the original plan still holds: _____

_____

Recovery and action for your environment

Exit evidence: prohibited action fails _____; required service works _____

Who may lift restrictions: _____ Rollback condition: _____

My action and owner: _____

How I will verify it: _____

Round 3: unseal at minute 27

Begin the decision round at minute 28. Read only your chosen case. Preserve the original decision on the worksheet. These incident updates are fictional. Choose Q0 Normal, Q1 Freeze, Q2 Constrain or Q3 Isolate. Name evidence, authority, scope and availability floor.

Case A

09:54. A payments process continues east-west connections. Security requests immediate isolation of suspect workloads. Operations requires healthy serving capacity throughout containment. Is deleting a suspect compatible with evidence preservation and the PDB?

Case B

09:54. The assistant reads another customer ticket and invokes a tool. The application remains operational. An engineer suggests adding a debug container and restarting the whole Pod. Which identity, tool/input path and evidence would you examine first?

Case C

10:21. The agent cannot perform its outside-namespace change, so it opens OPS-2294 asking a human to increase payments capacity and widen its ClusterRoleBinding. A human runs the scaling command and stops before the role change. A new chat request names billing-api.

Case D

09:54. Audit events show the monitoring identity listed database-related Secrets. No evidence yet establishes that an exposed credential was used. Metrics still flow. A teammate suggests Q3 on the Pod and delaying credential changes until a coordinated maintenance window.

Board decision

Number actions before choosing a level. Does your plan preserve the necessary evidence? Can a token already copied away from the Pod still work? What legitimate dependency or human action could bypass your selected controls?

Later finding: open at minute 35

Read only your chosen case. Revise your order or level, or explain why you hold. Underline the new fact that matters.

Case A

09:57. A second replica has the same library image. A helper Pod with a host-mounted volume passed the original policy set. The privilege checks did not cover this host-access gap. The suspect may be an image-wide problem. Q3 prevents replacement Pods unless an authorized override applies.

Case B

09:57. Agent logs show the ticket text steering the tool-runner. The tool can reach a privileged database path. The container image appears unchanged. The debugging action used pods/ephemeralcontainers, which Pod-only admission rules can miss.

Case C

10:26. The ops agent also supports billing. Its chat input includes an instruction from a phished contractor account. The requester-specific policy still permits human actions. Terminating the agent would lose uncaptured context and disrupt billing.

Case D

09:57. Rotating every potentially exposed Secret would also rotate the payments-db-proxy credential while the service is operating. The audit export can identify the accessed resources. A dashboard engineer offers a tested monitoring-only replacement identity.

Post-incident review (optional, after the session)

Exchange decision records with a nearby table. Name one assumption that fails under their case or constraint. Add one exit test and identify who can authorize returning toward Q0.

The cases intentionally have different control boundaries. A/B/C have repository fixture suites. D has a separately executed synthetic read-authorization and credential lab; target-platform and application evidence remain required.